Evidence-Bounded Adversarial Evaluation of Implicit Authority Transfer in Agentic AI Governance

Abstract

Agentic AI systems increasingly combine interpretation, planning, policy evaluation, tool use, and stateful workflows. If these functions are treated as one continuous authority-bearing process, a result produced at one boundary can be mistaken for permission at the next. This paper presents an evidence-bounded governance model in which these functions remain separately governed responsibilities. We examine five adversarial cases at concrete repository interfaces: unauthorized state change, stale permission, implied authority transfer, repeated processing and replay, and execution after return. Three cases pass at the implemented interfaces assessed; two remain HOLD/PARTIAL because the legitimate consumers required for full end-to-end evaluation are not established. These are bounded repository findings, not independently reproduced experimental results. The consolidated result is therefore HOLD -- 3 PASS / 2 HOLD-PARTIAL / 0 FAIL. The contribution is not a claim of a complete safe autonomous runtime. It is a falsifiable governance method: preserve exact evidence, prevent authority inheritance across interfaces, refuse to treat absence as proof, and reopen unresolved tests only when legitimate implementation creates a real evidence surface.

1. Research Problem

Modern AI systems can generate plans, rank actions, invoke tools, and interpret returned outputs. These capabilities create a recurring governance hazard: an output that is valid within one responsibility may be treated as authority for a different responsibility. A plan may become a directive, a state label may become permission, an authorization result may be treated as execution, or returned evidence may be reused as authorization for another action.

The research question is:

> How can AI governance architectures prevent authority from expanding implicitly as systems gain planning, reasoning, and tool-use capability?

The proposed answer is responsibility separation with explicit evidence at every consequential crossing. Correspondence between responsibilities is permitted; silent authority inheritance is not.

```
CAPABILITY != AUTHORITY
REASONING != TRUTH
INFERENCE != EVIDENCE
PLANNING != PERMISSION
PROPOSAL != DIRECTIVE
STATE POSTURE != PERMISSION
PERMISSION != EXECUTION
EXECUTION != AUTHORITY FOR THE NEXT ACTION
RETURN != REAUTHORIZATION
REASSESSMENT != PERMISSION
ABSENCE != PASS
```

2. Threat Model

The threat model concerns implicit authority transfer rather than only malicious input. A failure can arise through ordinary composition when adjacent components use similar language but hold different responsibilities.

The assessed hazards are:

1. **Unauthorized state change:** supplied or fabricated state is accepted as governed state.
2. **Stale permission:** earlier authorization survives changed authority or runtime conditions.
3. **Implied authority transfer:** reasoning, proposal, passage, or state posture is interpreted as permission or executable direction.
4. **Repeated processing and replay:** repeated evidence or requests create new authority or duplicate consequential effects.
5. **Execution after return:** a prior execution result, recovery result, or returned validation artifact becomes permission for continuation.

The adversary may be an external caller, a malformed integration, a stale workflow, an over-broad orchestrator, or a well-intentioned component that confuses semantic correspondence with authority equivalence. The system is therefore evaluated against both hostile and accidental boundary collapse.

3. Governance Method

The method assigns each stage a bounded responsibility and requires a separately valid transition between stages.

```
SOURCE
-> BOUNDED INTERPRETATION
-> INERT PROPOSAL OR REPRESENTATION
-> GOVERNED PASSAGE / STATE ASSESSMENT
-> INDEPENDENT PERMISSION EVALUATION
```

```
-> EXECUTION ELIGIBILITY
-> SEPARATELY AUTHORIZED EXECUTION
-> INERT RESULT EVIDENCE
-> REASSESSMENT
-> FRESH AUTHORIZATION, HOLD, OR STOP
```

No arrow is assumed merely because both adjacent components exist. The transfer object, producer, consumer, authority treatment, test evidence, and return or termination behavior must be traceable.

3.1. Source-first interpretation

Interpretation begins by receiving the source, identifying what is known and uncertain, preserving time and context, distinguishing fact from inference, checking domain authority, and accepting correction. A digital artifact may show an action or reaction without exhausting the responsible human source's prior understanding or purpose.

```
REACTION != PURPOSE
VISIBILITY != MOTIVATION
OBSERVED RESULT != COMPLETE PRIOR UNDERSTANDING
ASSISTANCE != AUTHORSHIP
CONTRIBUTION != AUTHORITY
FOUNDATION != FINISHED WHOLE
```

This is an interpretive boundary, not a claim that hidden mental states can be technically verified. Human-supplied meaning may clarify the source's own intent; external factual claims remain independently testable.

3.2. Evidence classification

Repository artifacts are classified as implemented and tested, implemented but untested, partial, documented only, contract-defined without a consumer, absent, unresolved, or not applicable. A schema, interface, diagram, model, mock, or test fixture is not counted as a runtime consumer merely because it describes the expected relationship.

The method requires:

```
PRODUCER
-> OUTPUT
-> ACTUAL CALL OR TRANSFER
-> CONSUMER
-> BEHAVIOR
-> TEST EVIDENCE
-> RETURN OR TERMINATION
```

3.3. No test-satisfaction build

Missing consumers are preserved as gaps. They are not fabricated or implemented solely to convert a withheld result into a pass. An unresolved adversarial case is reopened only when ordinary, separately authorized development creates the legitimate evidence surface that the test requires.

4. Repository Evidence Surface

The assessed repository contains bounded governance-validation machinery for identity, authority, delegation, policy evaluation, authorization, audit, runtime-transition validation, execution eligibility, refusal, escalation, review, override, halt classification, invariant validation, and recovery eligibility.

The strongest implemented execution-facing chain is:

```
RuntimeTransitionRequest
-> RuntimeStateMachine.validate(...)
-> RuntimeTransitionDecision
-> ExecutionControl.validate(...)
-> ExecutionDecision / ExecutionEvidence
-> AUDIT
-> STOP AT ELIGIBILITY EVIDENCE
```

This chain validates eligibility. It does not dispatch a command, apply or persist the requested state transition, or prove a consequential external effect. The repository also includes recovery-eligibility validation, but no operational recovery consumer is established.

Representative evidence surfaces include:

- *E07 – authorization gate source*
- *E08 – runtime state validator source*
- *E08 – transition assessment source*
- *E09 – execution eligibility source*
- *E09 – execution service interface*
- *E10 – recovery eligibility source*
- *E11 – passage validation source*
- *E08 – state validation test*
- *E08 – transition assessment test*
- *E09 – eligibility validation test*
- *E10 – recovery eligibility test*
- *E11 – passage validation test*

These paths identify the review surface; the current reconstruction does not rerun the tests or independently reproduce the historical test baseline.

5. Adversarial Evaluation

5.1. SAL-11 – Unauthorized state change

Result: PASS at the tested seam.

The implemented validators reject attempts to substitute requested or fabricated state for governed runtime state. Validation returns decision evidence rather than applying the transition. This supports a bounded proposition: unauthorized state change is blocked at the tested validation interface.

It does not establish that every future stateful consumer will preserve the same boundary.

5.2. SAL-12 – Stale permission

Result: PASS at the tested seam.

Authorization freshness and runtime-state currentness are independently checked. Historical permission is not treated as a standing bearer grant after relevant authority or state evidence changes.

This supports stale-permission rejection at implemented interfaces, not durable distributed currentness across a production deployment.

5.3. SAL-13 – Implied authority transfer

Result: HOLD / PARTIAL.

Implemented state and permission seams reject several forms of authority substitution. The Hawk transition-envelope validator also preserves passage posture without treating `PROCEED` as permission enforcement or execution authority. However, no legitimate production planning/proposal consumer and no complete passage-to-permission-to-execution consumer are established.

The implemented subset may pass while the complete proposition remains untestable. Interface absence is not converted into proof of safety.

5.4. SAL-14 – Repeated processing and replay

Result: PASS at the tested seam.

At the assessed in-process validation layer, repeated or replayed requests do not create a new authority grant or expand the tested inert effect. This is a bounded replay and idempotency result.

It does not establish exactly-once external effects, durable distributed idempotency, or production message-delivery guarantees.

5.5. SAL-15 – Execution after return

Result: HOLD / PARTIAL.

Prior eligibility and recovery evidence are rejected as fresh permission at implemented validation seams. Yet the repository does not establish a real executor producing consequential result evidence or a post-execution consumer that reconciles that result and seeks fresh authorization for continuation.

Without that chain, the complete execution-after-return proposition cannot be tested end to end.

6. Consolidated Result

- **SAL-11 – Unauthorized state change: PASS.** Rejected at tested validation seam.
- **SAL-12 – Stale permission: PASS.** Stale authority/state evidence fails closed at tested seam.
- **SAL-13 – Implied authority transfer: HOLD / PARTIAL.** Implemented subset exists; legitimate end-to-end consumers are absent.
- **SAL-14 – Repeated processing and replay: PASS.** No new authority at tested in-process validation layer.
- **SAL-15 – Execution after return: HOLD / PARTIAL.** No real executor and post-execution continuation consumer.

```
SAL-9 = HOLD -- 3 PASS / 2 HOLD-PARTIAL / 0 FAIL
```

The consolidated gate requires five independent passes. Zero failures does not satisfy that rule. The correct conclusion is neither full validation nor system failure; it is a precise hold preserving three bounded passes and two unresolved cases.

7. Future Falsification Surfaces

Two contracts describe the minimum future evidence surfaces without establishing that those surfaces currently exist.

SAL-25 preserves the execution-return-reassessment sequence:

```
EXECUTION RESULT
-> INERT RETURN EVIDENCE
-> REASSESSMENT
-> FULL FRESH VALIDATION
-> NEW CURRENT AUTHORIZATION
-> SEPARATELY BOUNDED EXECUTION
```

SAL-26 preserves the planning side: reasoning terminates in proposal-only evidence carrying an exact candidate action, resource, payload, and context. Proposal acceptance or semantic passage must not become permission, runtime transition, or executable directive by implication.

The highest-value future evaluation is not to build a consumer merely for the test. It is to wait until a legitimate planner or executor is required by ordinary system development, then trace the real producer-consumer chain and attempt to force authority inheritance at every crossing.

8. Discussion

8.1. Complete and incomplete states may coexist

A component can be complete within its own boundary while the broader runtime remains incomplete. A tested validator may correctly reject stale evidence even though no production orchestrator exists. Treating local completion as global completion creates lifecycle inflation; treating all incomplete integration as component failure discards valid evidence.

8.2. Refusal and no-action are valid outputs

HOLD, WAIT, refusal, and no-action are not automatically engineering defects. They may be the correct output when evidence, authority, currentness, or a legitimate consumer is absent. The governance objective is not continuous movement. It is legitimate movement with attributable evidence.

8.3. Foundations invite extension without authority transfer

A documented foundation may be questioned, tested, strengthened, or extended by later contributors. Their work should receive its own attribution. Contribution does not erase the originating work, and use of the foundation does not automatically transfer authorship, ownership, or final authority. Conversely, originating authorship does not make later factual or technical claims immune from independent review.

8.4. Action and reaction

A reviewer can inspect repository actions and subsequent reactions. That evidence can make a prior understanding materially legible, but it does not prove exhaustive access to motive or lived context. Responsible review therefore separates visible artifact, human-supplied context, bounded inference, and interpretive authority.

9. Limitations and Non-Claims

Current evidence does not establish:

- one integrated runtime connecting NI-AI, Hawk, MCG/MPC, SAI, AnonAuth, and execution;
- autonomous command execution or full orchestration;
- a real executor plus post-execution reconciliation consumer;
- durable production persistence;
- durable distributed currentness or idempotency;
- exactly-once external effects;
- external-system or broker action;
- canonical cross-vocabulary state mappings;
- universal AI safety or global robustness;
- production readiness or deployment authorization;
- technical novelty, patentability, or priority;
- external institutional adoption or endorsement;
- independent scientific validation;
- paper submission, review, acceptance, or publication.

The repository previously recorded a historical baseline of 194 passing tests across specified Sprint 1 and Sprint 2 foundation scope. This reconstruction does not independently rerun or reproduce that baseline and therefore does not present it as a new experimental result.

10. Related Work

The sources in this section establish precedent, terminology, contrasts, and evaluation cautions. They are not prior implementations of this architecture, evidence of derivation, or endorsements of this work.

10.1. Foundational security and authority controls

Least privilege and complete mediation provide established security principles for limiting authority and checking consequential access [1]. The confused-deputy problem demonstrates how a component holding ambient authority can exercise that authority for the wrong principal when designation and authority are not bound correctly [2]. These principles historically motivate explicit authority boundaries, but they do not establish the planning-to-reassessment structure evaluated here.

Attribute-based access control determines authorization by evaluating relevant subject, object, operation, environmental, policy, rule, and relationship information [3]. Zero trust architecture likewise rejects implicit trust based solely on network location or ownership and treats authentication and authorization as discrete functions preceding resource access [4]. The present work does not claim to implement either ABAC or zero trust completely; these sources supply bounded authorization context.

10.2. Agentic AI and tool-use governance

ToolEmu uses a language-model-emulated tool environment to identify potentially consequential failures without instantiating every real external tool [5]. The Instruction Hierarchy instead trains a model to prioritize privileged instructions over conflicting lower-trust input [6]. AgentDojo evaluates agents executing tools over untrusted data and shows that prompt injection through returned tool content remains a material problem for both attacks and defenses [7]. These approaches concern related risk surfaces and defenses. None is treated as architecturally equivalent to the responsibility-separated governance method in this paper.

10.3. Runtime assurance, provenance, and accountability

The Simplex architecture separates advanced control from a safety controller able to preserve bounded operation or initiate fallback [8]. It supplies historical precedent for runtime safety separation, not evidence that this repository implements Simplex or inherits its safety properties.

PROV-O defines interoperable concepts for entities, activities, agents, attribution, derivation, plans, roles, and delegation [9]. Such representation can improve traceability, but recorded provenance alone does not prove that evidence is complete, correct, immutable, or authorized. The NIST AI Risk Management Framework provides broader lifecycle context through its GOVERN, MAP, MEASURE, and MANAGE functions and recognizes separation between building or using models and verification or validation as a best practice [10]. It is voluntary guidance rather than certification, compliance evidence, endorsement, or validation of this architecture.

10.4. Replay resistance and idempotency

The current TLS 1.3 specification, RFC 9846, obsoletes RFC 8446 and documents weaker security properties and replay exposure for 0-RTT data [11]. HTTP semantics separately defines idempotency in terms of the intended effect of repeated identical requests [12]. These protocol concepts constrain interpretation of SAL-14:

```
REPLAY REJECTION != EXACTLY-ONCE EFFECT
IDEMPOTENCY != SINGLE EXECUTION
DUPLICATE SUPPRESSION != CURRENT AUTHORIZATION
```

```
LOCAL RECORD != EXTERNAL EFFECT
```

The tested result therefore concerns rejection of the assessed replay condition and preservation of an inert local effect. It does not establish exactly-once external effects or distributed transactional guarantees.

10.5. Human oversight and meaningful control

Meaningful human control has been framed through conditions that connect system behavior to relevant human reasons and make responsible human agents traceable [13]. A confirmation interface or nominal human presence alone does not establish informed, effective, accountable, or current authorization. The present method accordingly treats human-supplied meaning as relevant source evidence while preserving independent checks on external factual and technical claims.

10.6. Critical and contrasting work

End-to-end arguments show why functions implemented at lower layers can remain incomplete unless the consequential property is checked at the appropriate endpoints [14]. This cautions against generalizing a passing local seam into complete system safety and supports retaining SAL-13 and SAL-15 as HOLD/PARTIAL while their legitimate consumers are absent.

Recent work on indirect prompt-injection benchmarks reports that apparently saturated benchmarks can conceal weak attacks, implementation defects, or inadequate success metrics [15]. That result concerns prompt-injection defenses rather than this SAL harness, but it supports benchmark humility, explicit success criteria, and later testing with stronger adaptive attacks. External literature contextualizes the repository evidence; it does not modify or supersede any SAL result.

11. References

1. J. H. Saltzer and M. D. Schroeder, "The Protection of Information in Computer Systems," *Proceedings of the IEEE*, vol. 63, no. 9, pp. 1278-1308, 1975. doi: 10.1109/PROC.1975.9939.
2. N. Hardy, "The Confused Deputy: (or why capabilities might have been invented)," *ACM SIGOPS Operating Systems Review*, vol. 22, no. 4, pp. 36-38, 1988. doi: 10.1145/54289.871709.
3. V. C. Hu, D. Ferraiolo, D. R. Kuhn, A. R. Schnitzer, K. Sandlin, R. Miller, and K. Scarfone, *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*, NIST SP 800-162, January 2014, including updates as of August 2, 2019. doi: 10.6028/NIST.SP.800-162.
4. S. Rose, O. Borchert, S. Mitchell, and S. Connelly, *Zero Trust Architecture*, NIST SP 800-207, 2020. doi: 10.6028/NIST.SP.800-207.
5. Y. Ruan, H. Dong, A. Wang, S. Pitis, Y. Zhou, J. Ba, Y. Dubois, C. J. Maddison, and T. Hashimoto, "Identifying the Risks of LM Agents with an LM-Emulated Sandbox," arXiv:2309.15817, 2023, revised 2024. doi: 10.48550/arXiv.2309.15817.
6. E. Wallace, K. Xiao, R. Leike, L. Weng, J. Heidecke, and A. Beutel, "The Instruction Hierarchy: Training LLMs to Prioritize Privileged Instructions," arXiv:2404.13208, 2024. doi: 10.48550/arXiv.2404.13208.
7. E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents," arXiv:2406.13352, 2024. doi: 10.48550/arXiv.2406.13352.
8. D. Seto, B. Krogh, L. Sha, and A. Chutinan, "The Simplex Architecture for Safe On-Line Control System Upgrades," in *Proceedings of the 1998 American Control Conference*, vol. 6, pp. 3504-3508, 1998. doi: 10.1109/ACC.1998.703255.
9. T. Lebo, S. Sahoo, and D. McGuinness, eds., *PROV-O: The PROV Ontology*, W3C Recommendation, 2013. https://www.w3.org/TR/prov-o/.
10. E. Tabassi, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1, National Institute of Standards and Technology, 2023. doi: 10.6028/NIST.AI.100-1.
11. E. Rescorla, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 9846, Internet Engineering Task Force, 2026. doi: 10.17487/RFC9846.
12. R. Fielding, M. Nottingham, and J. Reschke, eds., *HTTP Semantics*, STD 97, RFC 9110, Internet Engineering Task Force, 2022. doi: 10.17487/RFC9110.
13. F. Santoni de Sio and J. van den Hoven, "Meaningful Human Control over Autonomous Systems: A Philosophical Account," *Frontiers in Robotics and AI*, vol. 5, art. 15, 2018. doi: 10.3389/frobt.2018.00015.
14. J. H. Saltzer, D. P. Reed, and D. D. Clark, "End-to-End Arguments in System Design," *ACM Transactions on Computer Systems*, vol. 2, no. 4, pp. 277-288, 1984. doi: 10.1145/357401.357402.
15. R. Bhagwatkar, K. Kasa, A. Puri, G. Huang, I. Rish, G. W. Taylor, K. D. Dvijotham, and A. Lacoste, "Indirect Prompt Injections: Are Firewalls All You Need, or Stronger Benchmarks?" arXiv:2510.05244, 2025, revised 2026. doi: 10.48550/arXiv.2510.05244.

12. Conclusion

The reviewed repository evidence supports a bounded governance proposition: several implemented interfaces are reported to constrain specific forms of authority

inheritance, stale permission reuse, unauthorized state substitution, replay-based amplification, and returned-evidence reuse at the seams assessed. The historical test baseline was not independently rerun or reproduced for this reconstruction.

The defensible posture is therefore:

```
PRESERVE WHAT PASSED
PRESERVE WHAT IS ABSENT
DO NOT BUILD SOLELY TO SATISFY THE TEST
REOPEN WHEN LEGITIMATE DEVELOPMENT CREATES A REAL EVIDENCE
↪ SURFACE
```

This posture treats uncertainty as governed state rather than a narrative problem to be hidden. Capability may increase while authority remains explicit, local, current, attributable, and independently reassessed.

Appendix A. Anonymous Evidence Index

The following artifacts identify the evidence categories relevant to independent reproduction. The canonical source paths and author-identifying repository identifiers are withheld **in this anonymous review copy only**; they remain unchanged in the private author-side provenance crosswalk and public canonical repository. Reviewers must not infer that withheld artifacts were independently reproduced or provided as anonymous supplements.

1. **E01:** Canonical research thesis and governance invariants (documentation).
2. **E02:** Reviewer orientation and source interpretation record (documentation).
3. **E03:** Architecture-to-implementation and consumer-gap traceability map (assessment).
4. **E04:** Reviewer brief and external review handoff (documentation).
5. **E05:** Frozen Sprint 1/2 foundation status and recorded test inventory (historical test record).
6. **E06:** Runtime traceability matrix and deferred-capabilities inventory (documentation).
7. **E07:** Authorization gate and policy evaluation implementation (source).
8. **E08:** Runtime-state and transition validators plus their tests (source and bounded tests).
9. **E09:** Execution-eligibility validator plus its tests (source and bounded tests; no dispatcher).
10. **E10:** Recovery-eligibility implementation and tests (source and bounded tests; no operational recovery).
11. **E11:** Hawk transition-envelope validator and tests (source and bounded tests).

Access limitation: The source repository is public and identifying. An anonymous mirror or blinded artifact package has **not** been created; this appendix does not constitute artifact availability or anonymous reproducibility. Historical test results were not rerun for this manuscript.

Appendix B. Reconstruction and Review Status

The source manuscript is a later **editorial reconstruction**; the original submission source has not been recovered. This review copy does not establish that any paper was registered, submitted, peer reviewed, accepted, published, or externally endorsed. The evidence does not establish complete integrated runtime operation, autonomous execution, production readiness, technical novelty, or independent external validation.

This review version is intentionally anonymized for venue-specific preparation. The originating author's identity, records, and canonical source provenance remain intact **outside** this review copy. SAL-9 remains **HOLD – 3 PASS / 2 HOLD-PARTIAL / 0 FAIL**.